

Lesson 14: Data Quality, Privacy, Security and Jobs

What's Left this Semester

- This is our last lecture, this is what is in store for the next few weeks:
 - 4/30: Database Security Lab
 - 5/5: CASE WHEN expressions and Common Table Expressions (CTEs)
 - 5/7: Window Functions
 - 5/12: Final Exam

Data as an Asset

- Proper investment into data (and the people/technology behind it) relies on seeing data as an organizational asset
- If we turn data into information to make decisions...
 - What's the potential gain by doing this better?
 - What's the potential cost of doing this poorly?
- How do we make sure everyone understands the value of data and information?

Data Quality

- **Dirty Data** can arise from:
 - Poor database design
 - Data-entry errors
 - Non-standardization
- From experience dirty data is bound to exist, but mitigation is the most important
- Dirty data can be cleaned up, but it's time consuming
- Data quality is the comprehensive approach to ensuring that data is accurate and valid
 - This is a **shared responsibility** no matter what anyone says!

Data Quality Acceptance

- Definitions may vary by business groups or divisions within an organization
 - Example: how a fundraising team and marketing team define a supporter
- Composite attributes may be broken down differently across systems
 - Example: breaking down an address
- Limited standardization across systems
 - Example: status codes

A Spreadsheet != Database

- Organizations that see data as an asset will have the tools and people to:
 - Implement and maintain database systems
 - Turn data into information to make decisions
 - Enact security and governance frameworks to protect data
 - Support end-users and meet business needs

Data Privacy

- Personally Identifiable Information or PII is data that by itself or in combination with other data might identify an individual
- PII must be treated with care, not only because it's the right thing to do
- PII poses financial, reputational risk and often regulatory risk
 - HIPAA and CCPA in the United States
 - GDPR in Europe

Collecting PII

- Sometimes it's necessary to collect PII in order to perform business operations and that's okay, but there should always be:
 - a clear and documented reason for capturing it
 - a plan for it's protection and destruction to prevent privacy harm
 - communication and transparency with the appropriate parties (legal and/or compliance)

Data Security

- Organizations should to have a **security policy** in place that outlines the standards, policies and procedures for ensuring the security of it's technology systems (including databases) to
 - mitigate **vulnerabilities** or the weakness of components within the technology systems
 - ensure that a vulnerability doesn't go unchecked and become a **threat**, posing an imminent security violation
 - prevent the worst case scenario of a **security breach**

Data Security in a Database

- Can be controlled at the:
 - DBMS Level
 - Database Level
 - Table/Object Level
 - Column Level
 - Function or Procedure Level
 - Row Level (not in MariaDB)

DBMS Level Security

- Users cannot have permissions for anything if they don't exist within the instance of a DBMS
- Users can be created manually (applications are good candidates)
- Preferably users are added through an integration with Active Directory
 - This adds extra layers of protection to ensure a user is granted access to systems in the first place

```
/*Add a user*/  
CREATE OR REPLACE USER 'root'@'localhost' IDENTIFIED BY 'password';
```

Database Level Security

- Users (or groups of users) can be granted access to specific database(s)

```
/*This is a good example of what not to do*/  
GRANT ALL PRIVILEGES  
ON hfh.*  
TO 'root'@'localhost'  
WITH GRANT OPTION;
```

Table Level Security

- Users (or groups of users) can be granted access to perform certain DML operations on tables within a database

```
GRANT SELECT, INSERT  
ON hfh.supporter  
TO 'root'@'localhost';
```

Column Level Security

- Users (or groups of users) can be granted access to perform certain DML operations for only specific on table within a database

```
/*Grant read-only access to two separate columns  
GRANT SELECT (supporter_id)  
  ON hfh.supporter  
  TO 'root'@'localhost';  
  
GRANT SELECT (first_name)  
  ON hfh.supporter  
  TO 'root'@'localhost';
```

Function/Procedure Security

- Users (or groups of users) can be granted permissions to run or use specific functions or stored procedures

```
/*Grant read-only access to two separate columns  
GRANT EXECUTE  
    ON hfh.sp_test_proc  
    TO 'root'@'localhost';
```

View Existing Grants

```
SHOW GRANTS FOR 'root'@'localhost';
```


Removing Permissions

- Instead of `GRANT` you can `REVOKE` permissions for specific users
 - Permissions can be revoked at all the same levels as they are granted.
- This might be necessary if:
 - Policies change
 - People leave the organization
 - Access was mistakenly granted

Defining Policies, Standards and Procedures

- **Policies** are general statements of direction used to manage an organization's operations through the communication and support of the the organization's objectives
- **Standards** describe the minimum set of requirements for carrying out a specific activity
- **Procedures** are the written instructions that describe the steps that need to be followed while carrying out a specific activity

Policies, Standards and Procedures in Context

- Policies
 - All users must have passwords and they must be changed every six months
- Standards
 - Passwords must be 10 characters long and contain at least two special characters
- Procedures
 - (1) New users must create a password before system access is granted, (2) to create a password the user submits it into the web form, (3) if it's valid, it is set, if not the user must try again, (4) finally the user submits the system access request form that requires manager approval

Roles in the Realm of Data

- Database Administrator
- Data Engineer
- Site Reliability Engineer
- Data/Business Intelligence Analyst
- Data Scientist

Generalized Responsibilities

Role	Responsibilities
Database Administrator	Design, implement and manage database(s) including focuses on performance, security and end-user support
Site Reliability Engineer	Responsible for system performance, availability, emergency response and monitoring
Data Engineer	Builds data pipelines between operational systems or from operational systems to analytical systems
Data/Business Intelligence Analyst	Generate insights related to KPIs, build dashboards/reports and conduct retrospective analyses
Data Scientist	Build analytical pipelines, conduct complex predictive analyses and ensures the rigor of statistical and experimental design

